4.2.5 AI Attacks Analysis and Controls

As AI becomes central to security operations, it also introduces new attack surfaces. This lesson surveys advanced AI-specific attack types and the controls needed to address them, guided by the **NIST AI RMF** and **Generative AI Profile**.

SECAI+ PREP

AI in Defense and as a Target

AI dramatically improves defensive capabilities but it also creates new attack surfaces that adversaries are actively probing.

AI-Powered Defense

Clusters high-volume signals, contextualizes incidents, and maps behaviors to ATT&CK frameworks for faster threat detection.

Red Team Probing

Red teams increasingly probe AI systems to find failure points *before* attackers do — stress-testing models under adversarial conditions.

Governance Framework

NIST AI RMF + Generative AI Profile provide the anchor for governance, engineering, and operational controls across the AI lifecycle.

Supply Chain & Transfer Learning Attacks

AI Supply Chain Attacks

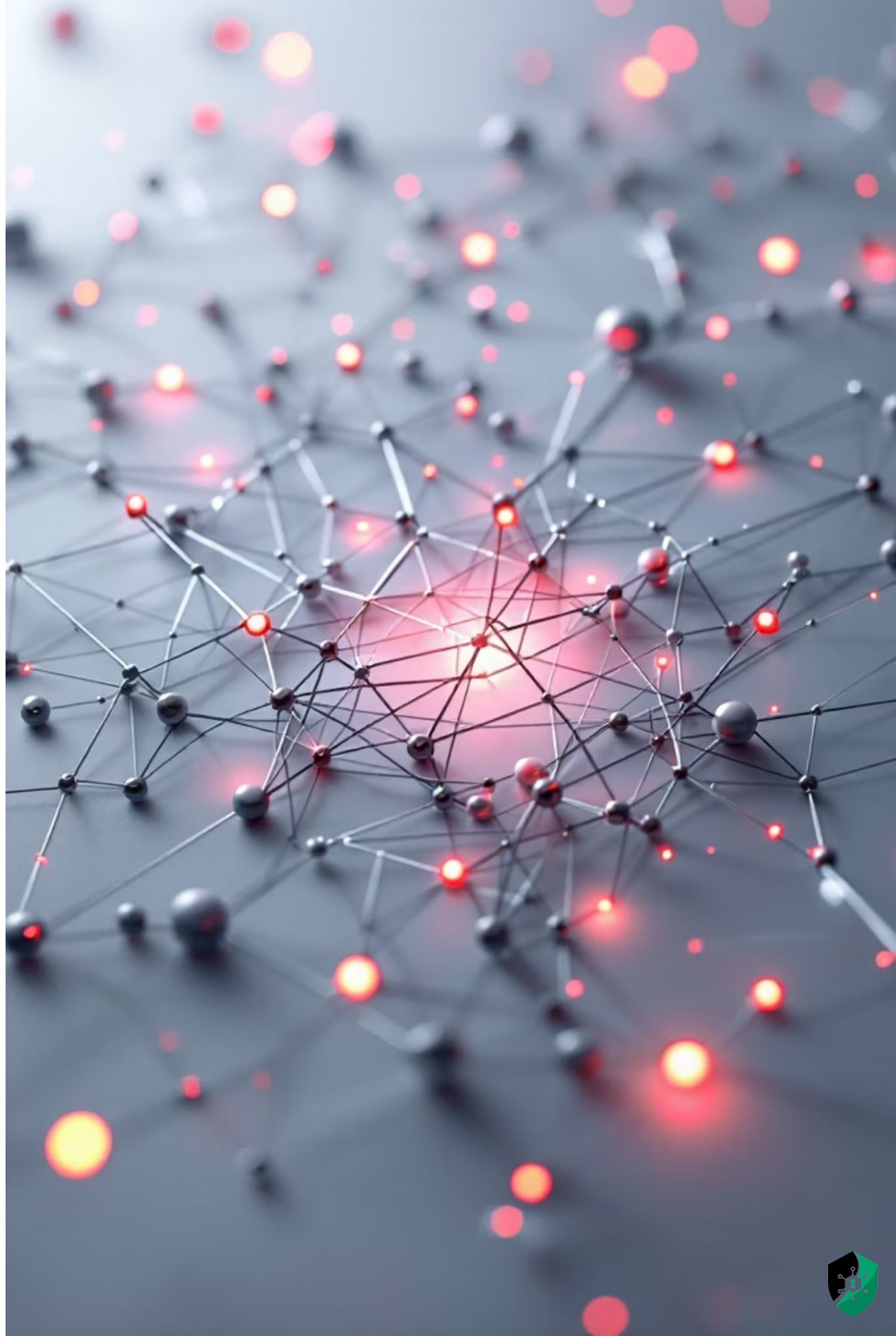
Pre-trained models and datasets sourced from public repositories can carry hidden backdoors or exfiltrate secrets. These must be validated with the same rigor as software packages.

- Backdoors embedded in public model weights
- Poisoned datasets from unverified sources
- Secret exfiltration via model behavior

Transfer Learning Attacks

Hidden behaviors from pre-training can persist even after fine-tuning on clean data — the model "remembers" malicious patterns.

- Source from trusted, verified curators
- Retrain with verified-clean datasets
- Apply fine-pruning techniques
- Inspect activation patterns for anomalies
- Use canary tests to detect hidden triggers



Sensitive Information Disclosure & Model Skewing

Sensitive Info Disclosure

Models may inadvertently reproduce training data, reveal system prompts, expose API keys, or leak prior session inputs to unauthorized users.

Controls: Output filtering, differential privacy, rate limiting, PII redaction, and continuous leakage monitoring.

Model Skewing (Data Drift)

Training distribution diverges from production data. Attackers can induce this deliberately to cause predictable, targeted failures.

The hidden danger: The model maintains high overall accuracy while *silently failing* on specific inputs — traditional metrics become deceptive and unreliable.

⚠️ **Critical Insight:** Model skewing is especially dangerous because standard accuracy metrics can mask targeted failures. A model can appear healthy while being systematically exploited on specific input classes.

Output Integrity, Membership Inference & Model DoS

Output Integrity

Model text consumed by downstream systems must be treated as **untrusted input**. Use structured outputs, allow-listed actions, and out-of-band approvals to prevent insecure output handling often mislabeled as prompt injection.

Membership Inference

An adversary determines whether a specific record was in the training set by analyzing confidence scores. Enabled by overfitting and excessive query access limit both to reduce exposure.

Model DoS

Availability attacks overwhelm model resources. Mitigate with rate limits, token and tool budgets, timeouts, and maximum chain depth restrictions to preserve uptime.

Plugins, Overreliance & Excessive Agency

As AI agents gain access to real-world tools such as email, storage, cloud APIs, the blast radius of any single attack grows dramatically.

1

Plugin & Agent Risk

Broad permissions mean a single prompt injection can trigger far-reaching actions across email, storage, and cloud systems.

2

Overreliance

Treating AI outputs as infallible undermines all other controls. Adopt a "**never-alone**" philosophy for high-impact decisions.

3

Excessive Agency

Granting agents more autonomy than necessary amplifies any attack or error into a major breach — the force multiplier effect.

- Least Privilege
- Human-in-the-Loop
- Narrow Tool Definitions
- Schema Validation
- Sandboxed Execution

Key Takeaways

1. **Anchor Frameworks**
   NIST AI RMF + Generative AI Profile are the foundation for AI risk governance across the full model lifecycle.

2. **Trust No External Source**
   Supply chain and transfer learning attacks exploit implicit trust in external model sources — validate everything like a software package.

3. **Filter, Redact, Rate-Limit**
   Sensitive info disclosure requires output filtering, PII redaction, and rate limiting as layered defenses.

4. **Metrics Can Lie**
   Model skewing is dangerous precisely because standard accuracy metrics can mask targeted, silent failures on specific inputs.

5. **Output Is Untrusted Input**
   Output integrity failures are often mislabeled as prompt injection — the real fix is treating all model output as untrusted input to downstream systems.

6. **Agency Is a Force Multiplier**
   The more autonomy an agent has, the worse any mistake or attack becomes. Least privilege and human-in-the-loop are non-negotiable.